

Forest Druid

Version: 3.6

User Guide

November 2025 (1)



Legal Notice

Copyright © 2025 Semperis. All rights reserved.

All information included in this document, such as text, graphics, photos, logos, and images, is the exclusive property and contains confidential information of Semperis or its licensors and is protected by copyright and trademark laws and various other intellectual property rights and unfair competition laws of the United States, foreign jurisdictions and international conventions. The information included in this document regarding processes, systems, and technological mechanisms is proprietary to Semperis and constitutes trade secrets of Semperis. No part of this publication may be reproduced, transmitted, transcribed, stored in a retrieval system, translated into any language or computer language, distributed, or made available to others, in any form or by any means, whether electronic, mechanical, or otherwise, without prior written permission of Semperis.

Semperis is a registered trademark of Semperis Inc. All other company or product names are trademarks or registered trademarks of their respective holders.

This document is provided strictly on an "AS IS" basis without warranty of any kind, either express or implied, including, but not limited to, the implied warranties of merchantability or fitness for a particular purpose. Semperis and its staff assume no responsibility for any errors that may have been included in this document and reserve the right to make changes to the document without notice. Semperis and its staff disclaim any responsibility for incidental or consequential damages in connection with the furnishing, performance, use of, or reliance on this document or its content.

Contents

Preface	4
Document Revisions	4
Styles and Conventions used in this Document	5
Contacting Semperis	6
Forest Druid Overview	7
What's New	7
Getting Started	9
System Requirements	9
Installing and Running Forest Druid	11
Forest Druid: Application Controls	13
Configure Security Zones	16
Adding New Security Zones	18
Importing Security Zones	19
Classify Direct Access Paths as Part of a Security Zone Perimeter	19
Export Security Zone Assessment	20
Configure Collection	20
Activity Log	22
Assessment Results	24
How to Use the Assessment Results	24
Defense Perimeter	26
Defense Perimeter: Page Controls	27
Defense Perimeter: Object List	28
Defense Perimeter: Relationship Graph	31
Attack Paths	34
Attack Paths: Paths List	35
Attack Paths: Graph	38
Default Tier 0 Objects	41
Types of Objects Collected	44
Object Type Icons	45
Privilege Escalation Relationships	47
Forest Druid Command Line Tool	54

Preface

Welcome to the *Forest Druid User Guide*. This document is intended for Security and IT professionals interested in performing an attack path analysis on an Active Directory environment or cloud Entra ID environment. It lists the system requirements for Forest Druid, explains how to unblock the zip file and extract the executable to ensure you can run the tool, and includes an overview of the assessment results.

Join the [Purple Knight Slack channel](#) to follow the community now using Forest Druid to track attack paths from security zone assets that violate the administrative tiering security model. Please send product inquiries or feature requests to pk-community@semperis.com.

Document Revisions

Table 1: Document Revisions

Product Version	Date	Document Revision	Comments
3.0	April 2024	1	Updated for 3.0 release; user interface enhancements, customize and create secure zones, and new privilege escalation relationships.
3.0	April 2024	2	Fixed typo for --collectionType parameter.
3.1	July 2024	1	Updated for 3.1 release; user interface enhancements, import zones from Forest Druid 3.0, and performance enhancements.
3.2	October 2024	1	Updated for 3.2 release; user interface and performance enhancements
3.3	December 2024	1	Updated for 3.3 release; user interface and performance enhancements.
3.4	March 2025	1	Updated for 3.4 release; updated Entra ID collected objects.

Product Version	Date	Document Revision	Comments
3.5	May 2025	1	Updated for 3.5 release; updated command line parameters.
3.6	November 2025	1	Updated for 3.6 release; added new control, updated existing controls, improved error handling, and other fixes.

Styles and Conventions used in this Document

The following styles are used in this document.

Table 2: Document conventions and styles

Typeface	Description
Bold	Used for names of UI elements, such as buttons, pages, menus, options, fields, and columns.
<i>Italics</i>	Used for references to documents that are not hyperlinks to other documents or topics. Also used for dialog names and to introduce new terms.
Monospace	Used for command-line input and code examples.
<PLACE HOLDER>	Brackets denote place holder text that is to be replaced with a user-specified value.

The following styles are used for notices:



NOTE:

This notice style is used to provide additional information and background overview.



IMPORTANT!

This notice style is used to present additional important information or warnings.

Contacting Semperis

Thank you for your interest in Semperis and Forest Druid. We are here to answer any questions you may have. Please send product inquiries or feature requests to pk-community@semperis.com.

Join the [Purple Knight Slack channel](#) to follow the community now using Forest Druid to track attack paths from zone assets that violate the administrative tiering security model.

CHAPTER 1

Forest Druid Overview

Forest Druid simplifies and accelerates attack path analysis by enabling you to prioritize exposure and vulnerabilities according to their proximity to assets in a security zone. Forest Druid collects objects and their access relationships from target environments to help you map out your secure identity perimeter. A Tier 0 zone will be created by default with predefined critical objects and connections to the zone. In addition, attack paths from identities will be displayed so you can audit and expand zones. You can then add additional security zones in order to produce well-defined security zones for your environment and identify all violations of the administrative tiering security model.

Forest Druid provides a point-in-time assessment, which is intended to assist cybersecurity defensive ("blue") teams and IT administrators audit direct relationships and exploitable attack paths to security zone objects, accelerating efforts to discover and eradicate threat actors that could compromise the enterprise identity infrastructure. It can also be used in post-breach scenarios to identify previously undisclosed domain-persistence techniques and eradicate threats from Active Directory.

What's New

The following features and enhancements are available in the latest release of Forest Druid.

Forest Druid 3.6

- You can now configure the criticality level of security zones on the **Configure Security Zones** page. The criticality level determines how critical the zone is compared to other security zones.
- The **Attack Paths** page has multiple updates:
 - A new control has been added, **Show critical paths only**. This control allows you to disable showing only critical paths. This allows you to see all the attack paths to your zones in the graph.

- The **Show paths between security zones** control has been updated with new options. You can now choose to display paths from lower criticality zones to higher criticality zones, display all paths between security zones, or display no paths between security zones.
- Most controls on the **Attack Paths** page have been updated with the  (Edit) button. Click this button to display the associated drop-down for the control.
- On the **Defense Perimeter** page, the **Show paths between security zones** control options have been updated with new text. The function of the control is the same.
- Improved error handling.
- Fixed declassified objects not being considered in the attack path analysis.
- The minimum width has been updated.

CHAPTER 2

Getting Started

This topic lists the system requirements for Forest Druid and explains how to unblock the zip file and extract the executable to ensure you can run the tool.

- [System Requirements](#)
- [Installing and Running Forest Druid](#)
- [Forest Druid: Application Controls](#)

System Requirements

The following apply when collecting data from each source type:

- **Active Directory:** The user running Forest Druid must have Read permissions to Active Directory. Running Forest Druid with elevated privileges, such as a Domain Admin, will return more objects and relationships. Forest Druid collects data for all domains in the Active Directory forest from which the currently logged in user belongs.
- **Microsoft Entra ID:** The user running Forest Druid must have Directory Read permissions in the Microsoft Entra tenant.

The Forest Druid collector command line tool provides some additional capabilities via optional parameters. That is, you can collect data from a machine that is not joined to a domain by passing the host name of the domain controller, or collect data using a different security context by passing the credentials of a user to run Forest Druid on behalf of. For more information on the Forest Druid collector command line tool, see [Forest Druid Command Line Tool](#).

Ensure the following system requirements are met when running Forest Druid.

Table 3: System requirements

Software/Hardware	Requirement
Operating system	Supported operating systems include: • Windows Server 2019
CPU	Minimum: 4 core
Memory	Memory and CPU requirements depend upon the number of users in your environment. The minimum recommended memory is as follows: • Small environments (~ 1,000 users): 4GB • Large environments (20,000 users or more): 16GB For very large environments, memory and CPU may need to be larger.
.NET Framework	Note that the required .NET Framework is packaged with Forest Druid.
Network Access	The following ports are required to run Forest Druid: • Local client -> DC (TCP 389): Used for domain discovery. • Local client -> DC (TCP 3268): Used for Global Catalog access. • Local client (port within TCP 8080-8100): Used for user interface web server. By default, Forest Druid attempts to find a port within the 8080-8100 range; however, if it does not find one, the start of the port range can be modified using the "UIWebServerPortOverride" property in the settings.json file. • Local port 5000: Used to communicate with and process requests from the backend process. If local port 5000 is being used by another application, you can configure a different localhost port using the "BackendURL" property in the settings.json file.

Table 3: System requirements

Software/Hardware	Requirement
Active Directory Permissions	Forest Druid requires permissions to enumerate all Active Directory Organizational Units and Containers including their child objects. Forest Druid also requires Read permissions for all enumerated objects' attributes: objectclass, objectguid, objectsid, name, primarygroup, member, ntsecuritydescriptor, msds-groupmsamembership, samaccountname, sidhistory, gplink, displayname, grouppolicycontainer.
Microsoft Entra ID Permissions	The user running Forest Druid requires Directory Read permissions in the Microsoft Entra tenant.
Display resolution	Minimum: 1350px X 600px  TIP: Use the following shortcut controls to adjust the zoom level in the application: • Zoom out: CTRL & SHIFT & - • Zoom in: CTRL & SHIFT & +

Installing and Running Forest Druid

To install Forest Druid, simply copy the contents of the zip file to a folder on your domain-joined machine. Please review the following instructions to ensure the zip file is unblocked and that you can run Forest Druid.

The license is built-in, which allows the utility to be run without entering a product license.

To install and run Forest Druid:**NOTE:**

Starting with Forest Druid 3.0, you can backup copies of your data by saving a copy of the **Database** folder (*Forest-Druid-Community/Backend/Database*). You can later replace the current **Database** folder with your saved copy to return the database to its previous state.

1. Download/copy the ForestDruid-Community.zip file.
2. Unblock the zip file.
 - Open the **Properties** dialog for the zip file.
 - On the **General** tab, select the **Unblock** check box in the **Security** section.
3. Extract the contents of the ForestDruid-Community.zip file to a folder with write permissions on a domain-joined computer (Windows workstation or server).
4. Double-click the **ForestDruid.exe** file to run Forest Druid.

**NOTE:**

If you did not unblock the zip file, the "Windows protected your PC" pop up displays. Click **More info** to display the app name and publisher. Verify that the publisher is **Semperis Inc.** before clicking the **Run anyway** button.

5. On the **Forest Druid License Agreement** dialog, select **I accept the terms in the license agreement**. Click **CONTINUE**.
6. On the **Please select the data you would like to collect** dialog, select one or both of the environments from which data is to be collected: **Active Directory** or **Entra ID**. Click **CONTINUE**.
7. If you select **Entra ID**, on the **Add Entra ID connections** dialog, click **ADD**. On the Microsoft sign-in dialog, enter the credentials to sign in to a Microsoft Entra tenant.

Repeat to add additional tenants. Once you have completed adding tenants, click **CONTINUE** to start the initial scan.

The first time you run Forest Druid, it performs a scan of the selected environment(s) to collect objects and their access relationships. While the collection process is in progress, a "Syncing Data" message and **Activity Log** pane are displayed. Once completed, the **Activity Log** pane displays the results of the scan.

For more information on the objects included in the assessment results, see the following topics in this guide:

- [Default Tier 0 Objects](#)
- [Types of Objects Collected](#)
- [Privilege Escalation Relationships](#)

**NOTE:**

The log file, *ForestDruid.log*, can be found in the **Logs** directory where you ran the Forest Druid application. In this log file you will find events performed by the backend and the collector.

Forest Druid: Application Controls

The application header appears across the top of the Forest Druid pages. It contains various navigation controls and action buttons.

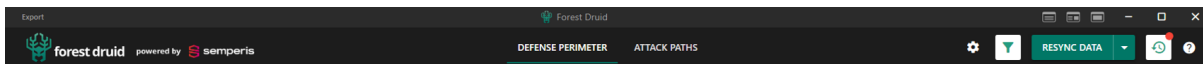


Figure 1: Forest Druid: Application header

Use the application header controls as described below:

Export

Saves the assessment results to a .CSV file.

For more information, see [Export Security Zone Assessment](#).

Screen layout options

Select from the following page layouts for the [Defense Perimeter](#) and [Attack Paths](#)

- **(Defense Perimeter Screen only)**  (Fullscreen relationship table): Displays the object list view only.
-  (Side-by-side view): Displayed by default, this shows the list and graph views side-by-side.
-  (Fullscreen graph): Displays the graph

view only.

New version available

When there is a new version of Forest Druid available, a **New version available** button is displayed in the application header. Clicking this button displays a pop up window with a link to the download page.

DEFENSE PERIMETER

Displays the **Defense Perimeter** page that can be used to define your security zones. This page focuses on immediate entry points into the security zones.

For more information, see [Defense Perimeter](#).

ATTACK PATHS

Displays the **Attack Paths** page that can be used to view and analyze inbound attack paths to security zones. This page provides a clear view of the entire attack path into a security zone perimeter.

For more information, see [Attack Paths](#).



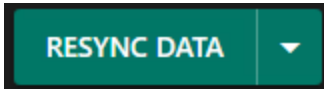
(Configure) Contains the **Configure Security Zones** and **Configure Collection** pages.

The **Configure Security Zones** page is where you can add objects to a security zone perimeter, view the account used to collect data, and create custom security zones (by default a Tier 0 zone containing all objects is added). For more information, see [Configure Security Zones](#).

The **Configure Collection** page is where you can add Microsoft Entra tenant connections, enable/disable data collection in environments, and add credentials to an unauthenticated tenant connection. For more information, see [Configure Collection](#).



(Data filter) Use the **Data filter** button to review smaller subsets of data. By default, all domains and tenants are displayed. Clicking this button displays a list of domains/tenants/zones from which you can select a smaller subset for display. The list also displays the date and time when the last synchronization took place for each domain and tenant.



Rescans the selected environment(s) to retrieve the latest data (objects and relationships).

The assessment results are a snapshot of the data collected when Forest Druid performed its initial scan (or the last rescan).

To retrieve the latest objects and their relationships, click this button to rescan the selected environment(s). The button displays "SYNCING" and spinning gears while the rescan is in progress. It also displays the **Activity Log** pane that shows a scan is in progress and the results once it has completed. Selecting the drop-down button allows you to select the specific data source(s) to sync (**Active Directory** and/or **Entra ID**).



NOTE:

*When you resynchronize data using the **RESYNC DATA** button, Forest Druid validates the authentication tokens for each Microsoft Entra tenant connection. If Forest Druid cannot authenticate to any of the Microsoft Entra tenants specified, you will be redirected to the **Collection Configuration** page to update the credentials. Click the **Update authentication** button to enter the correct credentials.*


NOTE:

Restarting Forest Druid does NOT automatically perform a new scan of the target environment(s).



(Activity History) Displays the **Activity Log** pane, which shows when a scan is in progress and the results once it has completed, when a filter has been applied, and when an object has been classified.

A red indicator in the top right corner of the button



() indicates that there was a change to the activity log since you last viewed it.

For more information, see [Activity Log](#).



(Help) Click this button to access the Forest Druid documentation website.

Configure Security Zones

Click the  (Configure) button in the application header to access the **Configure Security Zones** page. From this page you can view all security zones and a list of the objects that are being protected in each zone. By default a Tier 0 zone is created with some initially classified objects (for more information, see [Default Tier 0 Objects](#)), but additional custom zones can also be configured.

This page also allows you to easily expand a zone by classifying direct access paths directed to the zone or searching for objects by ID. Direct access paths are defined as paths with 0 cost (that is, easily exploitable). This can typically be found in scenarios like nested group membership.

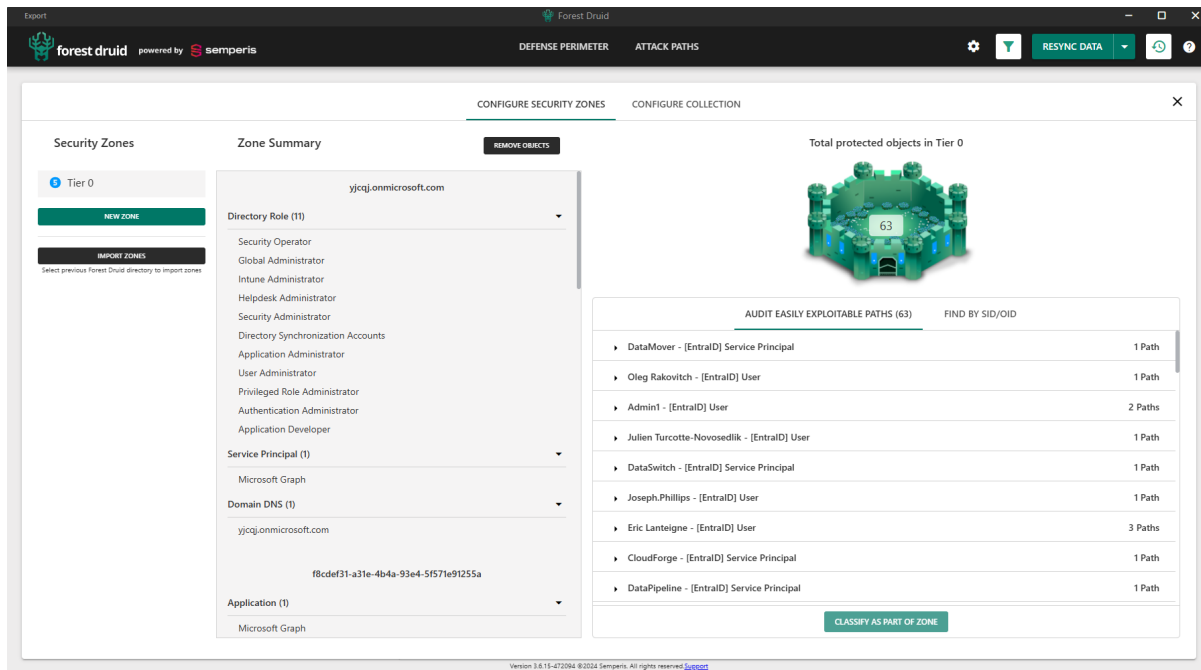


Figure 2: Configure Security Zones page

The following information and options appear on the Configure Security Zones page:

Security Zones

The **Security Zones** pane displays a list of available zones, as well as options for creating new zones ([Adding New Security Zones](#)) or importing zones from previous versions of Forest Druid ([Importing Security Zones](#)). By default, the Tier 0 zone (created during the initial data scan) is selected.

Hovering your cursor over a zone displays the following options:

-  (**Edit**): Use this button to edit the zone color, criticality, or name.
-  (**Delete**): Use this button to delete the zone.

Zone Summary

The **Zone Summary** pane is where you can view objects within a selected zone's secured perimeter. The listed objects are grouped by domain and object type.

Click the **Remove Objects** button to display individual check boxes appear for each of the listed objects. Once all objects have been selected, click **Remove** to apply changes or  to close.

**Total projected
objects in Tier 0**

This section displays a representation of the security zones perimeter which includes the total number of protected objects.

**Audit Easily
Exploitable Paths
(<nn>)**

Use this tab to view the direct access paths some objects have to the zone. You can use the **Find by SID/OID** tab to locate a specific object according to the SID or Object ID. All objects along a path can be approved as part of the zone by selecting the path and clicking **Classify As Part Of Zone**. For more information, see [Classify Direct Access Paths as Part of a Security Zone Perimeter](#).

You can also use the **Defense Perimeter** page to evaluate objects. For more information, see [Defense Perimeter](#).

Adding New Security Zones

The **Security Zones** pane on the **Configure Security Zones** page allows for new security zones to be created for Forest Druid.

**NOTE:**

The security zones created using previous versions of Forest Druid can also be imported. For more information, see [Importing Security Zones](#).

To add a new zone:

1. Click the **New Zone** button. A new zone will be added to the list.
2. (Optional) Customize the zone. Click the  (**Edit**) button then click the colored circle to customize the color and/or the criticality level.

This color will be used to indicate the secured objects in the zone throughout Forest Druid. The criticality level determines how critical the zone is compared to other security zones.
3. In the **Zone name** field, enter a unique name for the new zone.
4. Click  (**Add zone**) icon to save the new zone. Upon creation, no objects will be selected for this zone.

Importing Security Zones

The **Security Zones** pane on the **Configure Security Zones** page allows for security zones and classifications created in previous versions of Forest Druid to be imported into the latest version.



IMPORTANT!

Importing security zones from a previous version of Forest Druid will overwrite all existing zones (this includes the default Tier 0 zone).

To import a zone:

1. Click the **Import Zones** button.
2. In the dialog, locate and select the top level folder (ForestDruid-Community-v<version number>) for the previous Forest Druid version that contains the security zones to be imported.
3. Click **Select Folder** to import all of the zones and classifications from that version. This includes importing classifications for environments that may not exist in the new version. For example, if the previous version contained both Entra ID and AD environments and you have only configured AD in the new version, you would still be importing the Entra ID classifications even though they cannot be applied. Should you later configure Entra ID in the new version, these previously imported classifications will be applied upon initial collection.
4. A confirmation dialog will appear warning that existing zones and classifications will be overwritten. If you agree, select the check box.
5. Click **Confirm**.

Classify Direct Access Paths as Part of a Security Zone Perimeter

The following procedure explains the process for adding objects along a direct access path into the security zone perimeter via the **Configure Security Zones** page.

To classify direct access paths as part of a security zone perimeter:

1. On the **Configure Security Zones** page, the **Audit Easily Exploitable Paths (<nn>)** tab displays a list of the objects outside of the security zone perimeter that have a path from an identity to a zone which is composed of 0 cost

relationships (for example, from nested group membership). To add objects along a direct access path to the security zone perimeter, select the check box associated with the item.

You can also use the **Find by SID/OID** tab to find specific objects by entering either their SID or Object ID into the Search field.

2. Once you have selected an object(s) to move to within the security zone perimeter, click the **Classify As Part Of Zone** button. The list of objects will update to reflect the changes.

Export Security Zone Assessment

Once you have completed your analysis and identified legitimate objects in the security zone(s), you can export your assessment. Using this exported .CSV file, you can take the appropriate actions to remediate the attack paths to those objects to define your new security zone perimeter.

To export your security zone assessment:

In the top left corner of the application header, click **Export** and select the data to be exported:

- Export Defense Perimeter
- Export Attack Paths

A timestamped .CSV file is saved under a **\Backend\Reports** folder in the Forest Druid directory.

Configure Collection

Click the  (Configure) button in the application header to access the **Configure Collection** page. This page indicates which environments data is being collected from.



NOTE:

*When you resynchronize data using the **RESYNC DATA** button, Forest Druid validates the authentication tokens for each Microsoft Entra tenant connection. If Forest Druid cannot authenticate to any of the Microsoft Entra tenants specified, you will be redirected to the **Collection Configuration** page to update the credentials. Click the **Update authentication** button to enter the correct credentials.*

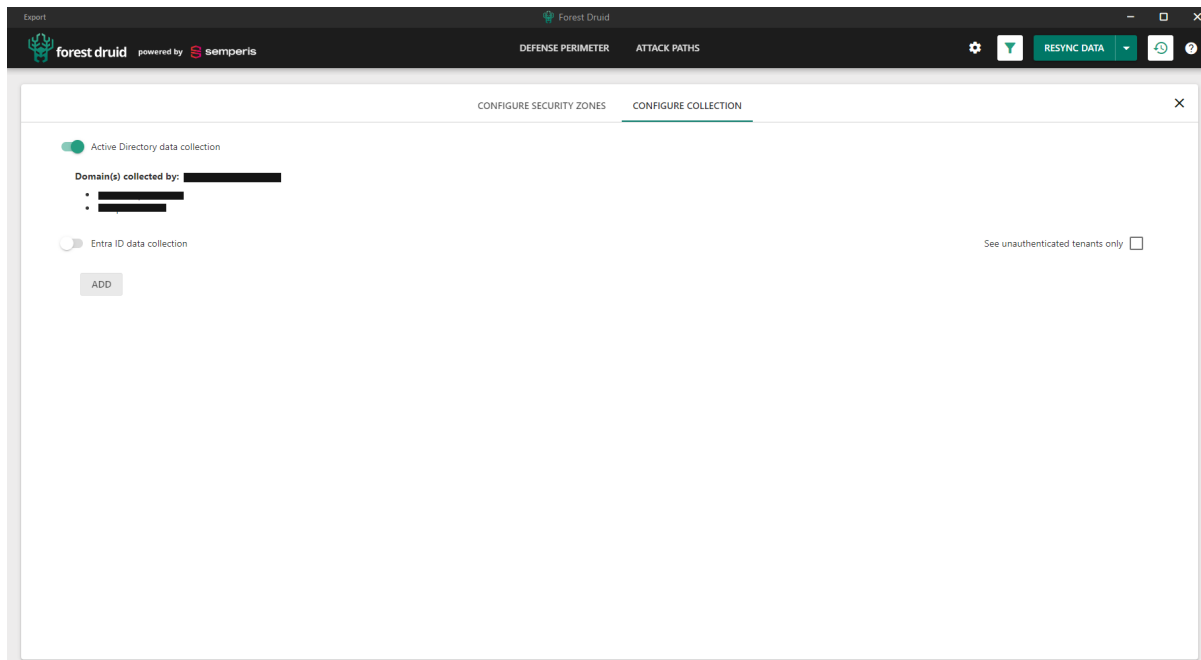


Figure 3: Configure Collection page

Each data source can be enabled or disabled using the toggle associated with it. When enabled, the data is available for collection by Forest Druid. When disabled, the data will not be collected until the data source has been re-enabled. In addition to the toggles, the following details are displayed for each environment.

Active Directory data collection

- **Domain(s) collected by:** The account(s) used to collect data from the specified on-premises Active Directory environment(s).

Entra ID data collection

- **Tenant Name:** The name assigned to the Microsoft Entra tenant.
- **Tenant Id:** The unique identifier associated with the Microsoft Entra tenant.
- **Authenticated user:** The user used to collect data from the tenant.
 - **Authenticated:** If the tenant connection has been established, a green check mark appears next to the **Authenticated** label.

If the tenant connection is not authenticated, click the **Update Authentication** button to enter the correct credentials.

- **X**: Click this button to remove the selected tenant connection. You can only remove tenants that have not yet been synchronized.
- **See unauthenticated tenants only**: Select this check box to view a list of unauthenticated tenant connections.
- **ADD**: Click this button to add an additional Microsoft Entra tenant.

To add a Microsoft Entra tenant connection:

1. Ensure **Entra ID data collection** toggle is enabled (green control is to the right).
2. Click **ADD**.
3. On the Microsoft sign-in dialog, enter the credentials to sign in to a Microsoft Entra tenant.

Once authentication is verified, the **Authenticated** switch is checked (green check mark) to the right of the tenant connection details.

Activity Log

Click the  (**Activity History**) button in the application header to display the **Activity Log** pane that summarizes the activities performed during the current session. "No activity history" is displayed if no activity has been performed.

A red indicator in the top right corner of the **Activity History** button () indicates that there was a change to the activity log since you last viewed it.

The **Activity Log** pane may contain the following information based on the activity taken during the current session:

- **Sync Data**: The results of each Active Directory synchronization operation performed during the current session.
- **Focused Target Applied**: Notification that a target has been set to focus on.

Click the forward arrow () to reapply the filter.

- **Focused Source Applied:** Notification that a source has been set to focus on. Click the forward arrow (↷) to reapply the filter.
- **Classified as <zone name>:** Notification that an object was classified to a zone. Click the back arrow (↶) to undo the classification.
- **Unclassified from <zone name>:** Notification that an object classification was removed. Click the back arrow (↶) to reapply the classification.
- **Exporting data:** Notification that an export was performed and the location of where the file can be found.
- **Import zones:** Notification when import operation occurs.
- **Loaded incoming relationships:** Notification when a user selects **Load incoming relationship(s)** for a node.

CHAPTER 3

Assessment Results

Once data collection is completed, Forest Druid displays the assessment results in 2 ways:

- The **Defense Perimeter** page displays the configured security zone objects and any immediate access relationships between the objects in security zones and other objects in the environment.

For more information, see the following appendices:

- [Default Tier 0 Objects](#) for a list of objects in the default Tier 0 security zone.
- [Types of Objects Collected](#) for a list of the types of objects being collected.
- The **Attack Paths** page displays the attack paths from identities leading to any object defined as part of a security zone, regardless of the number of hops (length). This page allows you to easily identify security principals that have access to objects in your security zone perimeter.

How to Use the Assessment Results

Forest Druid is intended to assist you in protecting your security zone assets by monitoring access relationships to them. In order to do that, you can run Forest Druid to identify the default Tier 0 security zone, expand it, and map what is actually a part of the security zone. You can also create custom zones for your data to further refine the data (for more information, see [Configure Security Zones](#)).

Suggested workflow for using the data presented in Forest Druid:

1. Launch Forest Druid to scan the selected environment(s) and calculate all possible attack paths to security zone objects. For more information, see [Installing and Running Forest Druid](#).

**NOTE:**

When an object has multiple paths to the security zone, Forest Druid displays the least costly path. This means that as objects are classified or filters are applied, the paths returned may vary.

2. Analyze results and further define your security zone perimeter.

Identify and approve legitimate relationships to security zone assets.

- On the **Configure Security Zones** page you can create and customize your security zones. All of the objects in the zone will be shown with the ability to remove any that should not be included. You can also approve direct access paths as part of the zone or search for objects to include by ID.
- On the **Defense Perimeter** page you will see objects with immediate connections to the security zone(s). Evaluate whether unclassified objects (orange node) should be part of the security zone they have a relationship to. If not, the relationship should be remediated. Focus on relationships with zero cost because they can be more easily exploited.
- On the **Attack Paths** page, review the attack paths leading into security zones. This page shows you all identities that have access to the security zone object regardless of the number of hops away.

Some attack paths may be worth prioritizing as they pose a more significant risk or act as a gateway to many potential attackers:

- Attack paths with low cost, since the lower the cost is for an attacker the easier it is to exploit.
- Attack paths with "Blowout nodes", which identify additional attack paths that allow multiple users access to a security zone. Remediating "Blowout nodes" could reduce the number of attack paths very quickly.

3. Add objects with approved relationships to the security zone by classifying them accordingly.

- From the object list (**Defense Perimeter**): click the  (Options) button, select **Classify to zone**, and select the appropriate zone from the list.

From the graph (**Defense Perimeter** or **Attack Paths**): right-click, select **Classify to zone**, and select the appropriate zone from the list.

- When you classify an object to a security zone, the data (lists and graphs) recalculates and displays the new security zone perimeter and attack paths, which can then be analyzed.
4. Repeat the analysis and reclassification steps for all unclassified objects.
 5. Export your security zone assessment, which can then be used as a remediation action plan. For more information, see [Export Security Zone Assessment](#).
 6. If there are changes to your environment(s), rerun Forest Druid and rescan to verify your new security zone perimeter.
 - Click the **RESYNC DATA** button in the application header.
 - Review and verify your new security zone perimeter--analyzing and remediating any additional risky objects that may be identified.

Defense Perimeter

After the scan completes, the **Defense Perimeter** page displays privilege escalation relationships to assets in security zones. From this page, you can classify objects as part of a security zone or identify objects that are in violation of the security model that need to be addressed.

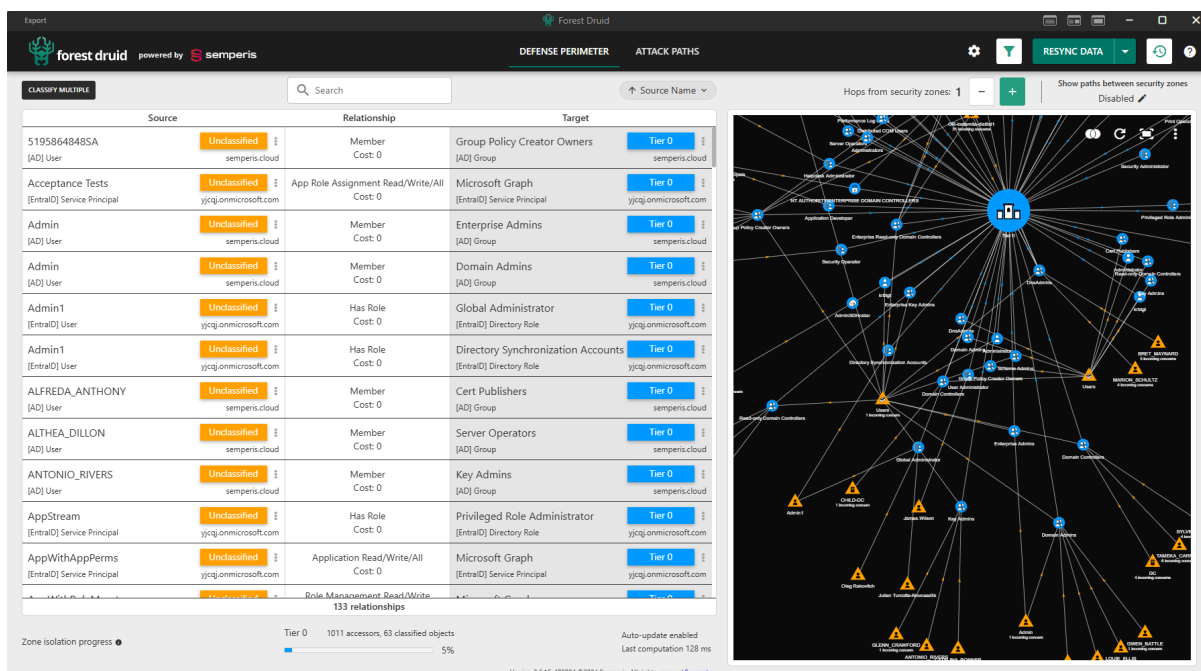


Figure 4: Defense Perimeter page

Colored nodes in the graph and object list help to differentiate secured objects from other objects:

- Colored circle: Security zone objects (by default this is a blue circle for objects in the Tier 0 zone). Custom colors for each zone (including the default Tier 0 zone) can be selected to represent these objects from **Configure > Security Zones**.
- Orange triangle: Unclassified objects that should be reviewed to determine if they should be classified as a security zone object or violate the security model.

Use the page, list, and graph controls to customize what is displayed on the **Defense Perimeter** page.

Defense Perimeter: Page Controls

By default, a split screen is displayed that includes both the object list and relationship graph showing all the objects with privileged relationships with a security zone object.

Use the page controls at the top of the **Defense Perimeter** page to change what is displayed:



NOTE:

Page controls are specific to the current page.

Hops from security zones: <nn>

By default, the graph and list shows all objects that are within one hop from a security zone. Use the + and - buttons to increase or decrease the number of hops from the security zones to be displayed. When you increase the hops, the additional relationships are added to both the list and the graph.

Show relationships between security zones

When you have multiple security zones configured, use this toggle to update the object list and relationship graph to display the relationships between security zones.

Show paths between security zones: <Disabled / Lateral Movement>

Click this toggle to select whether the graph displays all paths between security zones (**Lateral Movement**) or hides the paths between security zones (**Disabled**). By default, this is set to **Disabled**.

Defense Perimeter: Object List

The left pane in the **Defense Perimeter** page displays a list of all the objects with privileged relationships with a security zone object.

Use the object list controls as described below.

Classify Multiple

Click this button to enable the ability to multi-select sources and/or targets for inclusion in a security zones.

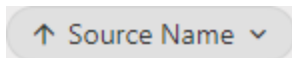
When enabled, individual check boxes appear for each of the listed sources and targets. Once all objects have been selected, click

Classify to apply changes or  to close.



Use the search control to conduct a search query within any field or a specific field in the list. The search results will also appear highlighted in the graph.

When a source/target focus is defined, the search is conducted within the filtered objects.



When you select a focused target/source filter (by default, Source Name Ascending), the selected target or source is displayed in the filtering control located above the list. In addition, the list and graph refreshes displaying the object's privileged relationships based on the selected filtering.

As filtering is applied, a **Show filters** link (that indicates the number of applied filters) is displayed above the table. Clicking the link will display all currently applied filtering.

The following details are displayed for each object in the list:



NOTE:

Filtering is applied to all views in to both the **Defense Perimeter** and **Attack Paths** page.

Source

The **Source** section of the table displays the following information for each object:

- The name of the object that has a relationship with another object.

- **Unclassified:** Clicking this button allows you to select a security zone to add the object to.
- The type of the source object. See [Types of Objects Collected](#) for the type of objects collected during the Active Directory scan.
- The name of the data source to which the source object belongs.


NOTE:

(Entra ID only) For scoped roles, the administrative unit will appear in brackets next to the role label.

Click the  (Options) button to display the following:

- Source information
- **Classify to zone:** Select this option to select a security zone to add the object to.
- **Remove classification:** Select this option to remove the zone classification. For already unclassified objects there will be no changes should this be selected.
- **Set as focused source:** Select this option to change the focus of the graph and list to show relationships and paths accessible from the node.
- **Set as focused target:** Select this option to change the focus of the graph and list to show relationships and paths directing to the node.

Relationship

The **Relationship** section of the table displays the following information for each object:

- The privilege escalation relationship the object has with a target object. See [Privilege Escalation Relationships](#) for a list of the relationships Forest Druid is looking for.
- **Cost:** The cost associated with the object, which is calculated based on ease of exploitation and stealthiness. Cost represents how difficult it is for an attacker to abuse an object--an object with a zero cost is extremely easy to exploit.

Target

The **Target** section of the table displays the following information for each object:

- The name of the target object.
- One of the following options:
 - **<zone name>**: This button displays the name of the zone the target appears in. Clicking this button allows you to change the security zone the target is assigned.
 - **Unclassified**: Clicking this button allows you to select a security zone to add the object to.
- The type of target object.
- The name of the AD domain or Entra ID domain to which the target object belongs.



NOTE:

(Entra ID only) For scoped roles, the administrative unit will appear in brackets next to the role label.

Click the  (Options) button to display the following:

- Target information
- **Classify To zone**: Select this option to change the security zone the target is assigned.
- **Remove classification**: Select this option to remove the zone classification. For already unclassified objects there will be no changes should this be selected.
- **Set as focused source**: Select this option to change the focus of the graph and list to show relationships and paths accessible from the node.
- **Set as focused target**: Select this option to change the focus of the graph and list to show relationships and paths directing to the node.

<nn> relationships

Displayed across the bottom of the objects list is the total number of objects in the list that have a privileged escalation relationship

with objects in the security zones.

The **Zone isolation progress** section is displayed beneath the object list. This section provides an overview of the progress made in classifying the listed objects for the zone (s). It includes the following information:

- **Tier 0 <nn> accessors, <nn> classified objects:** This section provides the total number of objects that can access the zone (accessors) followed by the number of the objects that have been classified. It includes a progress bar displaying the percentage of objects that have been classified for the zone (for example, 75% progress indicates the zone has 25% unclassified objects).
- The displayed information is automatically updated. The **Last computation** section displays the time (in milliseconds) since the last update occurred.

Defense Perimeter: Relationship Graph

Similar to the object list, the relationship graph (right pane) displays colored nodes to represent the objects collected during the Active Directory scan. Each displayed node also shows the number of incoming relationships that are of concern for that node (nodes with more than 50 concerning relationships will show **50+ incoming concerns**). In addition to the nodes, directional arrows show whether the relationship is incoming and/or outgoing. If you do not see the directional arrows, zoom in on the graph.



NOTE:

In the relationship graph, a dashed line with a "2+" label indicates multiple overlapping relationships and hovering over the label displays a brief summary of the collapsed relationships. Use the object list to view the relationships.

Use the following actions to manipulate the graph:

- Scroll to zoom in and out.
- Hold the left-click button and drag to pan the graph (lateral movement).
- Hover your cursor over a node to highlight the node's incoming relationships including their relationship labels. Clicking the node retains the highlighted state so you can highlight additional nodes and view their incoming relationships. Click the background to clear all node highlights.


NOTE:

An hourglass in the upper left corner of the graph indicates that a background operation is in progress.

Graph Controls

Use the buttons in the upper right corner of the graph as described below.

The **Undo node expansion** button appears after selecting **Load incoming relationship(s)** for one or more nodes. Clicking this button will undo the last node expansion performed using **Load incoming relationship(s)**. If multiple nodes have been expanded, clicking the button will undo each expansion in reverse order.



(**Toggle collapsed zones**) Click this button to display the following options:

- **Full collapse:** Displays a simplified view of the zones with only unclassified objects displayed.
- **Partial collapse (Targets shown):** (Default) Displays the zones including target objects. Relationships that can be bundled up in a collapsed node to the zone will be simplified to show a single node.
- **No collapse:** Displays all zones and all objects.



(**Reset Graph**) Click the this button to refresh the contents in the graph.



(**Zoom to fit**) Click the this button to resize the graph to fit the current screen.



(**More options**) Click this button to display the following options:

- **Enable node labels/Disable node labels:** Displays the name of the object for each node in the graph. (Enabled by default.)
- **Enable relationship labels/Disable relationship labels:** Displays relationship labels (for example, Owner, Member, and so on) for each incoming relationship. (Enabled by default.)
- **Enable incoming concern labels/Disable incoming concern labels:** Displays the incoming concern labels for each node. (Enabled by default.)
- **Toggle node spacing:** Allows you to increase the spacing between nodes in the graph. Clicking this option toggles between (small), (medium), and (large).

- **Switch to dark theme/Switch to light theme:** Changes the background color of the graph from dark (default) to light.
- **Pause auto-spacing/Unpause auto-spacing:** Changes whether auto-spacing is enabled or disabled. Auto-spacing is used to automatically adjust the spacing between objects when an object is moved in the graph.

These options are also available when you right-click on the graph's background (not a node in the graph).

Context Menu (Right-click Options)

The following options are available when you right-click on a node in the relationship graph:

- Object name and type: This is read-only information about the selected node.
- **Classify to zone:** Select this option to change the security zone to which the target is assigned.
- **Remove classification:** Select this option to remove the zone classification.
- **Set as focused source:** Select this option to change the focus of the graph and list to show relationships and paths accessible from the node.
- **Set as focused target:** Select this option to change the focus of the graph and list to show relationships and paths directing to the node.
- **See object details:** Select this option to open a dialog displaying details about the object. You can open multiple dialogs at a time in order to compare object details.
- **Load incoming relationship(s):** Select this option to display and highlight all incoming relationship(s) for the selected object. After selecting the option, you can use the  (Revert) button above the graph to revert to the previous graph state.

CHAPTER 4

Attack Paths

The **Attack Paths** page displays a list and graph showing the attack paths leading into security zones regardless of the number of hops (length).

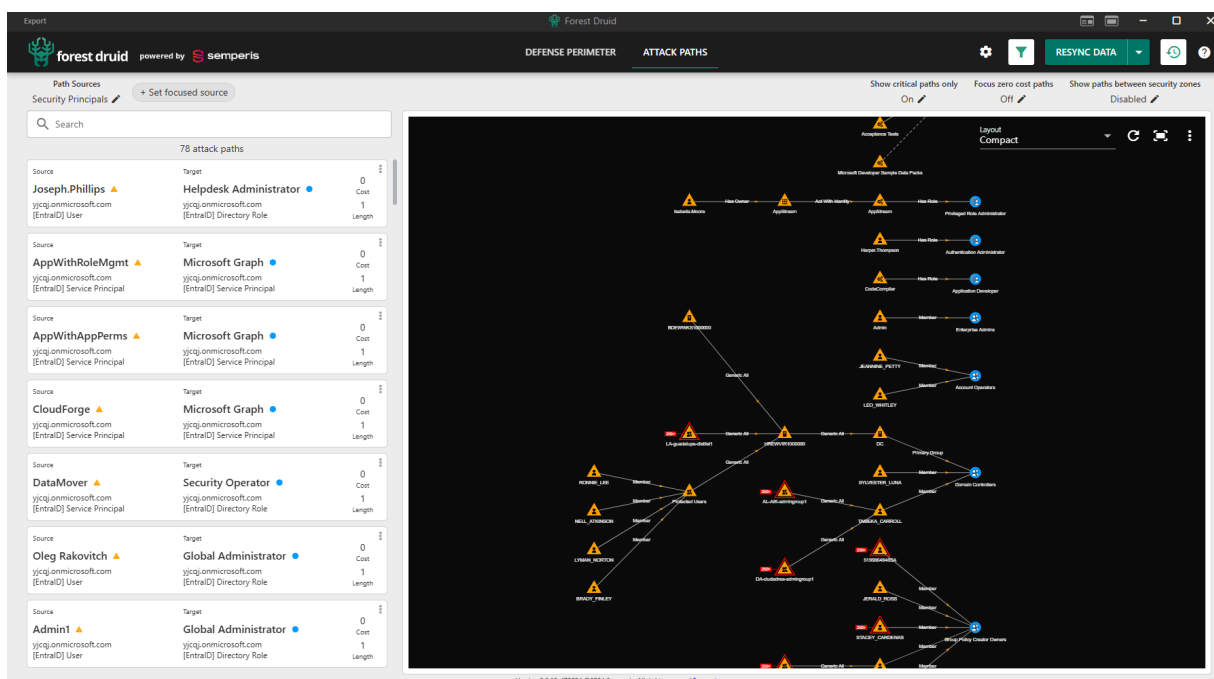


Figure 5: Attack Paths page (multiple domains)

From this list and graph, you can quickly see identities with escalation relationships with objects in the security zone.



NOTE:

When an object has multiple paths to a security zone, Forest Druid displays the least costly path. This means that as objects are classified or filters are applied, the paths returned may vary.

To see all attack paths for a source, set a source filter (right-click the node and select **Focus Source**).

The colored nodes used in the graph and in the list help to differentiate objects:

- Colored circle: Security zone objects (by default this is a blue circle for objects in the Tier 0 zone). Custom colors for each zone (including the default Tier 0 zone) can be selected to represent these objects from **Configure > Security Zones**.
- Orange triangle: Unclassified objects that should be reviewed to determine if they should be classified as a security zone object or violate the security model.

Use the page, list, and graph controls to customize what is displayed on the **Attack Paths** page.

Attack Paths: Paths List

The left pane on the **Attack Paths** page consists of "cards" that represent attack paths. Each card displays the security principal (source) and target object for a single attack path. The attack path cards in this list are sorted by associated cost with zero cost attack paths (easily exploited paths) listed first.

Each attack path card displays the following details:

- **Source:** The security principal that is the source of the attack path (left-most node in the attack path).
 - Name: The name of the security principal.
 - Domain/Tenant: The name of the domain or tenant to which the security principal belongs.
 - Type: The type of object, such as user, group and so on. See [Types of Objects Collected](#).

Blowout node: A *Blowout node* is an object that is an access point for more than 250 attack paths. Paths are no longer resolved beyond this object.

The blowout node limit can be modified using the "BlowoutIntersectionLimit" property in the settings.json file. Note that increasing this value may degrade performance.



NOTE:

(Entra ID only) For scoped roles, the administrative unit will appear in brackets next to the role label.

- **Target:** The target object of the attack path (right-most node in the attack path).
 - Name: The name of the target object and its classification icon (blue or green).
 - Domain/Tenant: The name of the domain or tenant to which the target object belongs.
 - Type: The type of object, such as user, group, and so on. See [Types of Objects Collected](#).


NOTE:

(Entra ID only) For scoped roles, the administrative unit will appear in brackets next to the role label.

- **Cost:** The cost associated with the attack path, which is calculated based on ease of exploitation and stealthiness. Cost represents how difficult it is for an attacker to abuse it--an attack path with a zero cost is extremely easy to exploit.
- **Length:** The number of hops between the source and target object.
-  (Options): Click this button to display the following:
 - **Focused source:** When you select a focused source, the selected source is displayed in the filtering control located above the list. In addition, the list and graph refreshes based on the selected filtering. Click  (Clear) to the right of the filter to be removed. The list and graph will refresh based on the new filtering.
 - **Focused target:** When you select a focused target, the selected target is displayed in the filtering control located above the list. In addition, the list and graph refreshes based on the selected filtering. Click  (Clear) to the right of the filter to be removed. The list and graph will refresh based on the new filtering.

Use the controls located above the list as described below:

Path sources

Click the  (Edit) button to display the **Path sources** drop-down, then select from the following filter options:

- **Security Principals:** (Default) When selected, only attack paths originating from security principals will be displayed. Security principals are entities that can be authenticated by the operating system, such as users or

service principals.

- **Any object:** When selected, all objects will be displayed.

Path targets

Available when a specific objects is set as the focused source, click the  (Edit) button to display the **Path targets** drop-down, then select from the following filter options:

- **Security zones:** (Default) When selected, only objects that are identities within the security zone will be displayed.
- **Unclassified security principals:** When selected, unclassified security principals (security principals that do not have paths to existing zones) will be displayed.

Set focused source

Click this to open a dialog where you can set the focused source using a SID or Object ID. On the dialog, enter either the SID or Object ID to use as the focused source in the field. Click **Search** to locate the desired source. Once you have located the source to use, select the source and click **Set as Focused Source**.

Show critical paths only: <ON / OFF>

Click the  (Edit) button to select whether the graph only displays the most critical paths from each identity (**ON**) or includes all paths (**OFF**). By default, this is set to **ON**.

Focus zero cost paths: <ON / OFF>

Click the  (Edit) button to select whether the graph displays only paths with zero cost (**ON**) or includes all paths (**OFF**). By default, this is set to **OFF**.

Show paths between security zones: <Disabled / Privilege Escalation / Lateral Movement>

Click the  (Edit) button to select whether the graph only displays paths from lower criticality zones to higher criticality zones (**Privilege Escalation**), displays all paths between security zones (**Lateral Movement**), or hides the paths between security zones (**Disabled**). By default, this is set to **Disabled**.

Use the search control to conduct a search query within any column in the paths list.

When a source/target focus is defined, the search is conducted

within the filtered paths.

<nn> Attack Paths

Displays the number of attack paths in the selected environment (s).

Attack Paths: Graph

The graph on the **Attack Paths** page displays a graphical representation of the attack paths leading into objects in a security zone regardless of the number of hops. An attack path displays the source security principal (left-most node), the target object (right-most node), as well as all additional objects within the attack path leading into the target object.



NOTE:

Tips for the Attack Paths graph:

- In the graph, a dashed line with a "2+" label indicates multiple overlapping privilege escalation relationships and hovering over the label displays a brief summary of the collapsed relationships.
- To view all the overlapping relationships, click the object's card in the object list or apply both the target and source filters in the graph.

In addition to the nodes, directional arrows show whether the relationship is incoming and/or outgoing. If you do not see the directional arrows, zoom in on the graph.

Use the following actions to manipulate the graph:

- Scroll to zoom in and out.
- Click the background and drag to pan the graph (lateral movement).



NOTE:

The hourglass in the upper left corner of the graph indicates that a background operation is in progress.

Graph Controls

The following options appear in the upper right corner of the graph :

- **Layout:** Use this drop-down to select a layout configuration for the graph. The following options are available: **Compact** (default), **Align Sources**, **Align**

Targets, and Force-spaced.

-  (**Reset Graph**): Click this button to refresh the contents in the graph.
-  (**Zoom to fit**): Click this button to resize the graph to fit the current screen.
-  (**More Options**): Click this button to display the following options depending on the selected layout:
 - **Switch to dark theme/Switch to light theme**: Changes the background color of the graph from dark (default) to light.
 - **Pause auto-spacing/Unpause auto-spacing**: (Force-spaced layout only) Changes whether auto-spacing is enabled or disabled. Auto-spacing is used to automatically adjust the spacing between objects when an object is moved in the graph.
 - **Node spacing**: (Compact, Align Sources, and Align Targets layouts only) Move the toggle from left to right to increase the spacing between nodes in the graph.
 - **Relationship spacing**: (Compact, Align Sources, and Align Targets layouts only) Move the toggle from left to right to increase the spacing between privilege escalation relationships in the graph.
 - **Column spacing**: Move the toggle from left to right to increase the spacing between columns in the graph.
 - **Reset spacing configuration**: Click this button to reset all spacing configurations to their default state.

Context Menu (Right-click Options)

In addition, similar to the relationship graph on the **Defense Perimeter** page, the following right-click options are available for the nodes in this graph:

- Object name and type: This is read-only information about the selected node.
- **Classify to zone**: Select this option to change the security zone to which the target is assigned.
- **Remove classification**: Select this option to remove the zone classification. For already unclassified objects there will be no changes should this be selected.
- **Set as focused source**: Select this option to change the focus of the graph and list to show relationships and paths accessible from the node.

- **Set as focused target:** Select this option to change the focus of the graph and list to show relationships and paths directing to the node.

APPENDIX A

Default Tier 0 Objects

The following objects are defined as objects in the default Tier 0 security zone, which are represented as nodes (by default, blue) on both the **Defense Perimeter** and **Attack Paths** pages.

Active Directory

Containers:

- Admin SD Holders

Groups:

- Account Operators
- Administrators
- Backup Operators
- Cert Publishers
- Distributed COM Users
- DnsAdmins
- Domain Admins
- Domain Controllers
- Enterprise Administrators
- Enterprise Key Admins
- Enterprise Read-only Domain Controllers
- Enterprise Domain Controllers
- Exchange Admins
- Exchange Domain Servers
- Exchange Enterprise Admins
- Exchange Enterprise Servers

- Exchange Servers
- Exchange Windows Permissions
- Exchange Organization Administrators
- Exchange Trusted Subsystem
- Group Policy Creator Owners
- Incoming Forest Trust Builders
- Key Admins
- Organization Management
- Performance Log Users
- Print Operators
- Read-only Domain Controllers
- Remote Desktop Users
- Schema Admins
- Server Operators

Objects:

- domainDNS (Partition Head)

Users:

- Administrator
- Krbtgt

Entra ID**Roles:**

- Application Administrator
- Authentication Administrator
- Authentication Policy Administrator
- Billing Administrator
- Cloud App Security Administrator
- Cloud Application Administrator
- Conditional Access Administrator

- Directory Synchronization Accounts
- Exchange Administrator
- External Identity Administrator
- Global Administrator
- Helpdesk Administrator
- Password Administrator
- Privileged Authentication Administrator
- Privileged Role Administrator
- SharePoint Administrator
- User Administrator

Accounts:

- Microsoft Graph

APPENDIX B

Types of Objects Collected

Active Directory

The types of objects that are collected when Forest Druid scans an on-premises Active Directory environment include:

- User
- Group Managed Service Account
- Computer
- Group
- Organizational Unit
- Container
- Domain DNS
- Built-in domain
- Foreign security principals
- Any other object that is a derivative of the objectClass of the previous objects

For each object collected, Forest Druid captures the following information (if available):

- displayName
- gPLink
- member
- msDS-AllowedToActOnBehalfOfOtherIdentity
- msDS-AllowedToDelegateTo
- msDS-GroupMSAMembership
- name

- nTSecurityDescriptor
- objectClass
- objectGUID
- objectSID
- primaryGroupID
- sAMAccountName
- sIDHistory
- userAccountControl

Entra ID

The types of objects collected when Forest Druid scans an Entra ID environment include:

- Administrative Unit
- Devices
- Directory Role
- Domain (and tenant)
- Group
- Serviceprincipal
- User

Object Type Icons

The following icons are used in Forest Druid to help you identify the different object types.

Table 4: Object type icons

Icon	Object type
	User
	Group
	Computer
	Domain DNS
	Container, RPC Container, Exchange System Objects Container

Icon	Object type
	OU
	Built-in Domain
	GPO
	SID
	Foreign Security Principal
	Group Managed Service Account
	ms-Imaging-PSPs
	Service Principal
	Directory Role
	Application

APPENDIX C

Privilege Escalation Relationships

Takeover relationships are types of relationships that are "strong" in that they allow the privileged owner to control the object. Privilege escalation relationships are when a non-security zone object has a takeover relationship with an object in a security zone. The Forest Druid assessment results reveal where objects in lower tiers have privilege escalation relationships with security zone assets.

Active Directory

The types of privilege escalation relationships that are collected by Forest Druid include:

- **Add Self**

Source object has the ability to add itself to the target group.

- **Add Allowed To Act**

Source object has the ability to modify the *msDS-AllowedToActOnBehalfOfOtherIdentity* attribute on the target object; allowing configuration of Resource-Based Constrained Delegation (AllowedToAct).

- **Add Member (ExtendedRight)**

Source object has the ability to add other objects to the target group; due to security group delegation, members of a security group have the same privileges as that group.

- **Add Member To Gmsa Group (ExtendedRight)**

Source object has the ability to modify the *msDS-GroupMSAMembership* attribute on the target object; granting the ability to delegate permissions to read a group managed service account password (ReadGMSAPassword).

- **All Extended Rights (ExtendedRight)**

Source object holds write permissions to attributes on the target object; including the ability to read protected attributes, such as BitLocker (*msFVE-RecoveryInformation*) and LAPS (*ms-Mcs-AdmPwd*).

On a user object, this can extend to setting *ForceChangePassword* and for groups *AddMember* rights.

- **Allowed To Act**

Source object can perform Kerberos Resource-Based Constrained Delegation on the target object; configured within the *msDS-AllowedToActOnBehalfOfOtherIdentity* attribute on the target object.

- **Allowed To Delegate To**

Source object is trusted to impersonate (delegate) any user to the target object; configured within the *msds-AllowedToDelegateTo* attribute on the source object.

- **Contains**

Source container or organizational unit contains the target object.

- **DirSync Read Filtered Set**

Through a directory synchronization (DirSync), the source object can be used to replicate directory changes (*DS-Replication-Get-Changes*).

- **Force Change Password (ExtendedRight)**

Source object can reset the password of the target object, without knowing the existing password.

- **Generic All**

Source object has full control over the target object.

- **Generic Write**

Source object has the ability to write/update any non-protected attribute on the target object.

- **Get Changes (ExtendedRight)**

Source object has the ability to replicate changes from a given naming context (NC).

- **Get Changes All (ExtendedRight)**

Source object has the ability to replicate changes from a given naming context (NC), including domain secret data, such as passwords.

- **GPLink**

Group policy object is linked to the target organizational unit.

- **GPLink Edit**

Source object has the ability to link group policy changes on the target organizational unit.

- **Member**

Source object is a member of the target group object.

- **Owner**

Source object is the owner of the target object that allows for security descriptor modifications.

- **Primary Group**

Primary group of the source object matches one of the defined security zone groups.

- **Read GMSA Password**

Source object has the ability to retrieve the group managed service account (GMSA) password on the target object.

- **Read LAPS Password**

Source object has the ability to read the local administrator password stored in the *ms-Mcs-AdmPwd* attribute on the target objects.

- **SID History**

Source object has a SIDHistory value that matches one of the defined security zone groups.

- **Write Account Restrictions**

Source object has the ability to write to the *ms-DS-AllowedToActOnBehalfOfOtherIdentity* attribute on the target object, making the target object susceptible to a Resource-Based Constrained Delegation (RBCD) attack.

- **Write All Properties**

Source object has the ability to modify all writable properties on the target object.

- **Write Dacl**

Source object has the ability to update the discretionary access control list (DACL) on the target object, allowing any permission to be delegated/set.

- **Write Owner**

Source object has the ability to modify the owner on the target object, granting the ability to modify object security descriptors regardless of permissions on the target object's discretionary access control list (DACL).

- **Write SPN**

Source object has the ability to set a service principal name (SPN) on the target object, making the target object susceptible to a kerberoasting attack.

Entra ID

The types of Entra ID privilege escalation relationships that are collected by Forest Druid include:

- **Act With Identity**

Created between the Azure app registration and its service principal when the service principal must authenticate to the Microsoft Entra tenant.

- **Add Member**

This relationship is derived based on the permissions that a service principal has with Microsoft Graph. The Add Member relationship is included when the service principal has any of the following MS Graph app role assignments:

MS Graph app role	Relationship included in Forest Druid
Directory.ReadWrite.All	Between the service principal and all non-role-assignable Azure AD security groups found in the tenant.
Group.ReadWrite.All	Between the service principal and all non-role-assignable Azure AD security groups found in the tenant.
GroupMember.ReadWrite.All	Between the service principal and all non-role-assignable Azure AD security groups found in the tenant.
RoleManagement.ReadWrite.Directory	Between the service principal and all Azure AD security groups, including both non-role-assignable and role-assignable groups, found in the tenant.

- **Add Owner**

This relationship is created for service principals:

- To all Azure app registrations and service principals, when the following permission is present:
 - Microsoft Graph Application.ReadWrite.All
- To all Azure service principals, when the following permission is present:
 - Microsoft Graph ServicePrincipalEndpoint.ReadWrite.All
- To all Azure security groups, when one of the following permissions are present:
 - Microsoft Graph Directory.ReadWrite.All
 - Microsoft Graph Group.ReadWrite.All
- To all Azure security groups and all Azure app registrations, when the following permission is present:
 - Microsoft Graph RoleManagement.ReadWrite.Directory

In addition, this relationship is created:

- To all groups within defined scope, if an assigned role has one of the following permissions:
 - microsoft.directory/groups/owners/update
 - microsoft.directory/groups.unified/owners/update
 - microsoft.directory/groups.security/owners/update
 - microsoft.directory/groups/allProperties/allTasks
- To all applications, if an assigned role has one of the following permissions:
 - microsoft.directory/applications/owners/update
 - microsoft.directory/applications/allProperties/allTasks
- To all other service principals, if an assigned role has one of the following permissions:
 - microsoft.directory/servicePrincipals/owners/update
 - microsoft.directory/servicePrincipals/allProperties/allTasks

- **Has Owner**

This relationship is created between the object and any owner objects for groups, applications, and service principals.

- **Add Secret**

This relationship is created for service principals:

**NOTE:**

*It is only created against other service principals when the **App instance property lock** is NOT enabled (Advanced settings) with **All properties** or **Credentials used for verification** locked properties.*

- To all Entra ID app registrations and service principals, when the following permission is present:
 - Microsoft Graph Application.ReadWrite.All

In addition, this relationship is created:

- To all applications, if an assigned role has one of the following permissions:
 - microsoft.directory/applications/credentials/update
 - microsoft.directory/applications/allProperties/allTasks
 - microsoft.directory/applications.myOrganization/credentials/update

- **Has Role**

Indicates that a principal (source object) has been granted a particular Entra ID administrator role.

- **Member**

The given asset (source object) belongs to a security group. Groups in Entra ID may grant their direct members any privileges the group itself has. For example, if a group has a Microsoft Entra ID administrator role, direct members of the group inherit those permissions.

- **Directory Read/Write/All**

Source object has been granted the Directory.ReadWrite.All permission and therefore has the ability to read and write data in an organization's directory, including users and groups. The source object does not, however, have the ability to delete users or groups or reset user passwords.

- **Application Read/Write/All**

Source object has been granted the Application.ReadWrite.All permission and therefore has the ability to create, read, modify, update applications secrets, and delete applications and service principals.

- **AdministrationUnit Read/Write/All:**

Source object has been granted the AdministrationUnit Read/Write/All permission and therefore has the ability to create, read, modify, and delete administrative units and unit membership.

- **App Role Assignment Read/Write/All**

Source object has been granted the AppRoleAssignment.ReadWrite.All permission and therefore has the ability to grant application permissions to any API (including Microsoft Graph). The source object also has ability to manage application assignments for any application.

- **Group Read/Write/All**

Source object has been granted the Group.ReadWrite.All permission and therefore has the ability to create groups, update group properties and memberships, and delete groups.

- **Group Member Read/Write/All**

Source object has been granted the GroupMember.ReadWrite.All permission and therefore has the ability to list groups, read basic properties, read and update group memberships.

- **Role Management Read/Write Directory**

Source object has been assigned the RoleManagement.ReadWrite.Directory permission and therefore has the ability to read and manage the role-based access control (RBAC) settings for the organization's directory.

- **Service Principal Endpoint Read/Write/All**

Source object has the ability to modify any service principal endpoint in Entra ID.

- **User Read/Write/All**

Source object has been assigned the User.ReadWrite.All permission and therefore has the ability to read and write profile properties, group membership, and a user's reports and managers. Also allows the source object to create and delete non-administrative users.

APPENDIX D

Forest Druid Command Line Tool

You can run the Forest Druid collector (collector.exe) as a command line tool, which is useful when:

- you need to explicitly specify the domain controller to be used
- you need to explicitly specify the username and password for the user collecting Active Directory information
- the current machine is not domain-joined
- unattended mode is required, such as when running a scheduled script

The Forest Druid command line tool, `collector.exe`, can be found in the **Backend** directory of the **ForestDruid-Community** download package.

Command line parameters

The following command line parameters are supported.

Table 5: Parameters list

Parameter	Values	Description
--collectionType	Required: false Type: CollectionType Default: AD	Use to define the environments to be scanned. Valid values are: • AD • EntraID
--hostname	Required: false Type: string Default: None	Use to explicitly specify the domain controller or domain name to be used to connect to Active Directory forest.

Parameter	Values	Description
		Use this parameter when the collector is run from a non domain-joined computer having network access to the forest.
--scope	Required: false Type: Scope Default: Forest	Use to specify the scope of your scan. Valid values are: - Forest: By default, Forest Druid collects data for all domains in the Active Directory forest where you are currently logged in. - Domain: Set the scope to "Domain" to collect data for only the domain where you are currently logged in.
--user	Required: false Type: string Default: None	Use to explicitly specify the user running Forest Druid. You can specify either the UPN (username@domain) or netbios username (domain\username).
--password	Required: false Type: string Default: None	Use to specify the password associated with the user account.
--database	Required: true Type: string	Use to specify the location where the database files are to be stored. Default location is [ProductFolder]/Database. When -storageType is set to None, this parameter is not required because no database files are stored.

Parameter	Values	Description
--storageType	Required: false Type: StorageType Default: File	Use to specify the type of storage to be used. By default, the data is stored to the database at the location specified in the -database parameter. However, you can specify the following option: None: The mode used to just enumerate Active Directory without saving it to the database. This mode is used for troubleshooting scenarios when you need to understand whether Active Directory can be quickly enumerated and all objects and attributes can be counted.  NOTE: <i>The location of the database (--database parameter) is not required when you use the -None option because no database files are being stored.</i>
--help		Use to display the help information.
--version		Use to display the version information.

Parameter	Values	Description
--pagesize	Required: false Type: int Default: None	Use to define the maximum number of entries returned per page by an LDAP query response, when using paged queries.
--rangesize	Required: false Type: int Default: None	Use to define the maximum number of attribute values that can be retrieved in a single LDAP query, when performing range retrieval queries.
--entraId.CollectSessionData	Required: false Type: Boolean Default: false	Use to collect Entra ID Sign On data.
--entraId.CollectDevices	Required: false Type: Boolean Default: false	Use to collect information on the available Entra ID devices.
--maxbinarylength	Required: false Type: int Default: 71680	Use to define the maximum supported ACL size.
--collectionMode	Required: false Type: CollectionMode Default: Scan	Use to define the mode of collection. Valid values are: • Scan • Incremental
--anonymize	Required: false	Use to ensure stored data is anonymized.


NOTE:

To view data collected by the command line interface, copy the latest Backend/Database/##### folder and Backend/Database/Database.txt file to the Backend/Database folder of another instance of Forest Druid. Data will be loaded into the Backend/Database/Trinity folder along with any previously collected data from that instance.

Examples

The following example collects enumeration statistics for the raptordc domain controller and stores the enumeration statistics in the collector.log file. Since storage type is none, no data is written to the database.

```
collector.exe -b "C:\Users\Administrator\Desktop\ForestDruid-Community\Database" -h raptordc -s None > collector.log
```

The following example runs the collector from a non domain-joined machine, specifying domain controller from the forest that needs to be collected and the credentials to be used for collection.

```
collector.exe -b "C:\Users\Administrator\Desktop\ForestDruid-Community\Database" -h DC01 -u "administrator@raptor.local" -a "password_is_here"
```